2026/2027

Fundamentos de Ciberseguridad

CIB

JUAN RIVERA ORDÓÑEZ
IES LOS SAUCES – DAW2

Fundamentos de ciberseguridad

Ejercicio 1.1 2
1. Amenazas y vulnerabilidades informáticas. 2
2. Medidas de protección básicas. 12
3. Análisis de los incidentes de seguridad. 17
4.Herramientas y tecnologías de aplicación. 24
5.Normativa y buenas prácticas de uso. 31
Webgrafía 33

Ejercicio 1.1

1. Amenazas y vulnerabilidades informáticas.

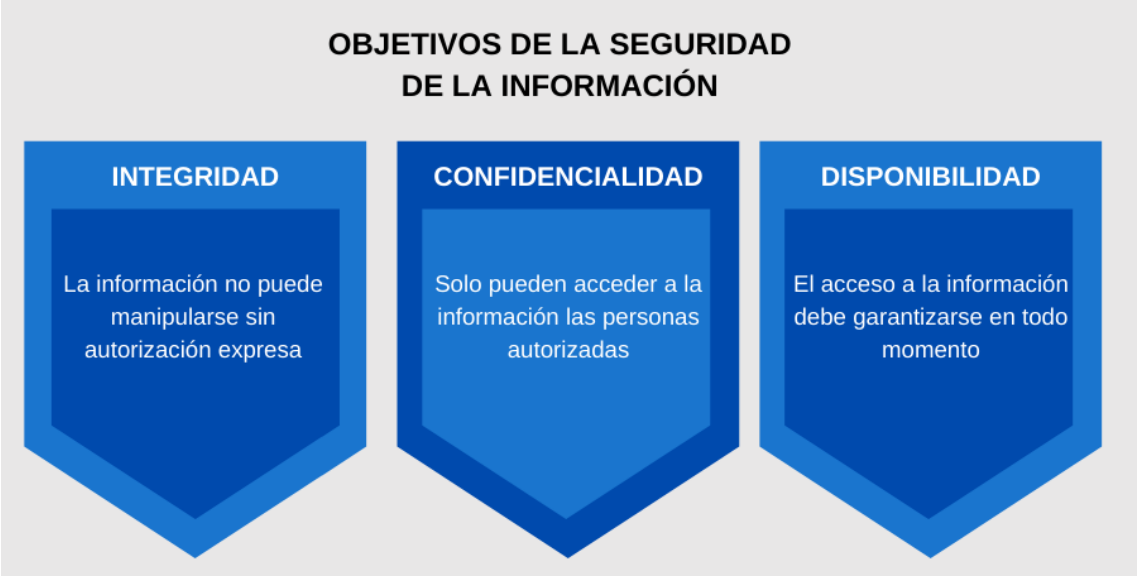
Conceptos básicos, diferencias entre amenazas activas y pasivas y su impacto.

Confidencialidad: Es la propiedad de la información que garantiza que este accesible únicamente a personal autorizado a dicha información.

Integridad: Datos o información exactos y fiables y que no han sido modificados accidentalmente o de manera intencional.

Disponibilidad: Asegura la fiabilidad y el acceso oportuno a los datos y recursos por parte de los individuos o personas autorizadas.

Diferencias → Cada uno protege un aspecto diferente del ciclo de vida de los datos.



Amenazas Pasivas

- Pérdida de privacidad y secreto industrial o comercial.
- Exposición de credenciales, datos financieros o información médica.
- Facilita la preparación de futuros ataques activos más dirigidos.

Ejemplos comunes: Sniffing, Análisis de tráfico...

Amenazas Activas

- Pérdida de integridad de los datos (información falsa o corrupta que lleva a malas decisiones operativas).
- Parálisis total o parcial de servicios críticos (pérdida económica inmediata por caída de plataformas).
- Daño reputacional severo y posibles sanciones regulatorias (por ejemplo, multas RGPD).

Ejemplos comunes: Suplantación de identidad, Modificación de mensajes, Ataques de denegación de servicio, Ransomware o inyección de malware...

Clasificación y características de las principales amenazas informáticas.

Tipos de malware

Adware: Muestra anuncios no deseados en la pantalla del ordenador o dispositivo móvil, redirige los resultados de las búsquedas a sitios web de publicidad y recopila los datos de los usuarios para venderlos a anunciantes sin su consentimiento.

Spyware: Se oculta en el dispositivo, controla tu actividad y roba información confidencial como datos financieros, información de cuentas, contraseñas y mucho más.

Ransomware: Diseñado para bloquear el acceso de los usuarios a su sistema o denegar el acceso a los datos hasta que se pague un rescate.

Troyanos: Se oculta como software legítimo con el fin de engañarte para que ejecutes software malicioso en tu equipo.

Gusanos: Son uno de los tipos de malware más comunes, se propagan en redes informáticas mediante la explotación de vulnerabilidades del sistema operativo.

Virus: Es un fragmento de código que se inserta en una aplicación y se ejecuta cuando esta se abre.

Keyloggers: Es un tipo de spyware que vigila la actividad del usuario.

Bots y botnets: Es un equipo infectado con malware que un hacker puede controlar de manera remota.

Técnicas de ingeniería social

Es una estrategia utilizada por personas o grupos para manipular y engañar a las personas con la intención de que revelen información delicada o lleven a cabo acciones que pongan en riesgo su seguridad.

Phishing



Los atacantes envían correos electrónicos, mensajes o enlaces engañosos a **sitios web que parecen legítimos** con el fin de confundir a los destinatarios para que hagan clic y revelen información delicada, como contraseñas, números de tarjetas de crédito o datos personales.

Phishing personalizado



Parecido al *phishing* pero **muy adaptado a cada persona**. Para resultar aún más convincentes, los atacantes personalizan los mensajes basándose en información concreta sobre el objetivo.

Baiting:



Los atacantes **ofrecen algo atractivo**, como descargas gratuitas de *software*, a cambio de información personal o acceso al sistema. Esta forma de actuar puede incluir archivos o enlaces infectados.

Pretexting:



Los atacantes elaboran una historia ficticia o un pretexto para obtener información. Esto implica a menudo **suplantar la identidad de alguien que inspira confianza**, como un colega o un representante de un banco.

Phishing de voz



Una forma de *phishing* que tiene lugar **mediante la comunicación por voz, habitualmente mediante una llamada telefónica**. Los atacantes se hacen pasar por entidades de confianza y convencen a las víctimas de que revelen información delicada.

Suplantación



Los atacantes **se hacen pasar por otra persona**, ya sea en línea o en persona, para ganar confianza y manipular al objetivo de forma que revele información confidencial o haga algo concreto.

Phishing en redes sociales



Los ataques **se dirigen principalmente a usuarios de redes sociales** y a menudo aprovechan un tema popular o una tendencia para crear mensajes engañosos, haciendo que parezcan pertinentes y fiables.

Programas de secuestro y extorsión



Los atacantes amenazan con **revelar información delicada** o perturbar los sistemas a menos que se pague un rescate. Infunden miedo para coaccionar a sus víctimas.

Ataques a la red

Acción deliberada para comprometer la seguridad, disponibilidad o integridad de los sistemas conectados.

Denegación de servicio (DoS/DDoS): Es un tipo de ciberataque en el que un actor malicioso tiene como objetivo que una máquina u otro dispositivo no esté disponible para los usuarios a los que va dirigido, interrumpiendo el funcionamiento normal del mismo.

Ataque de intermediario (MITM): Es un ciberataque en el que un hacker roba información confidencial espiando las comunicaciones entre dos objetivos en línea, como un usuario y una aplicación web.

Ataques a aplicaciones web

Intento por parte de agentes maliciosos de aprovechar las vulnerabilidades y debilidades de las aplicaciones web o móviles creadas durante el proceso de desarrollo de software, con el objetivo de interrumpir la actividad empresarial u obtener acceso al ecosistema de TI de una organización.

Inyección SQL: Es un método de infiltración de código intruso que se vale de una vulnerabilidad informática presente en una aplicación en el nivel de validación de las entradas para realizar operaciones sobre una base de datos.

Cross-site scripting: es un tipo de ataque informático que permite a un actor de amenazas ejecutar código malicioso en el navegador de otro usuario.

Clasificación de vulnerabilidades en sistemas, redes y aplicaciones.

Vulnerabilidades de sistema operativo

Permiten el acceso a atacantes que dañan los dispositivos donde está instalado.

Las páginas web pueden distribuir códigos maliciosos, de manera que, cuando un usuario las visita, se descarga automáticamente un archivo que infecta el dispositivo.

Vulnerabilidades de red

Se ubican en la infraestructura del hardware, en el software o en procesos organizacionales del sistema. Este tipo de vulnerabilidad informática puede ser física o no física:

- *Físicas:* como alojar el servidor en un lugar cuyas condiciones no son aptas y pueden dañarlo —por ejemplo, en un área poco ventilada, húmeda, con riesgo de inundaciones o incendios— o donde personas no autorizadas pueden acceder de forma fácil.
- *No físicas:* como un acceso inalámbrico mal protegido, cortafuegos mal configurados o un software obsoleto que no tiene los parches adecuados para nuevas amenazas.

Vulnerabilidades de aplicaciones web

Afectan al software de uso específico, especialmente en entornos web.

Inyección de código (Injection): Inserción de comandos maliciosos (como SQL) no filtrados por la aplicación.

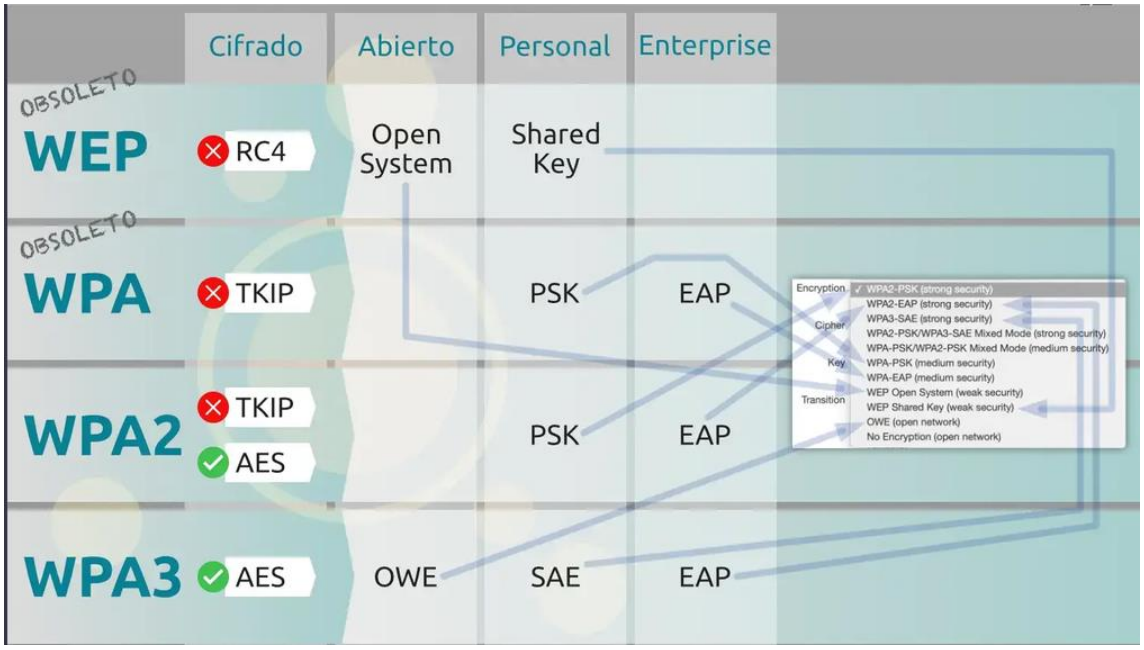
Control de acceso roto: Fallos que permiten a un usuario ver o hacer cosas sin la autorización debida.

Componentes vulnerables: Uso de librerías o dependencias de terceros desactualizadas.



Redes inalámbricas sin cifrar o con cifrados obsoletos.

Las redes inalámbricas sin cifrar o con protocolos antiguos como WEP exponen todo tu tráfico de internet a que cualquier intruso lo lea o robe en cuestión de minutos.



Relación entre amenazas y vulnerabilidades.

La relación entre amenaza y vulnerabilidad se basa en que la vulnerabilidad es la debilidad interna que permite que una amenaza externa o potencial cause un daño.

Amenaza: Un evento, agente o circunstancia externa o potencial que puede provocar un daño o ataque.

Vulnerabilidad: Un fallo, punto débil o característica propia de un sistema que lo hace susceptible a dicha amenaza.

Mecánica de explotación: identificación de vulnerabilidades por los atacantes.

Los atacantes identifican vulnerabilidades mediante análisis automatizados, investigaciones de seguridad y escaneos de red para encontrar fallos que luego puedan aprovechar.

Resumen de como DETECTAR y Explotar VULNERABILIDADES



Ejemplos prácticos de explotación: ransomware en sistemas desactualizados e inyección SQL.

Casos reales de ataques Exploit

A lo largo de los últimos años, los exploits han estado detrás de algunos de los ciberataques más sonados a nivel mundial. Estos casos muestran cómo una vulnerabilidad no corregida puede desencadenar consecuencias millonarias y afectar a miles de organizaciones.

- **WannaCry (2017)**

  Este ransomware se propagó utilizando el exploit EternalBlue, que aprovechaba una vulnerabilidad crítica en Windows. En pocos días afectó a hospitales, fábricas y empresas de todo el mundo, provocando pérdidas estimadas en más de 4.000 millones de dólares.

- **Equifax (2017)**

  Una de las mayores brechas de datos de la historia: más de 147 millones de registros personales quedaron expuestos debido a una vulnerabilidad no parcheada en Apache Struts. Los atacantes usaron un exploit conocido y ya corregido, pero la empresa no había aplicado la actualización.

- **Microsoft Exchange (2021)**

  Exploits de día cero permitieron a atacantes acceder a miles de servidores de correo corporativos en todo el mundo. El incidente derivó en robo masivo de datos y puertas traseras instaladas para acceso persistente.

- **Log4Shell (2021)**

  Una vulnerabilidad crítica en la librería Log4j, muy utilizada en aplicaciones Java, permitió la ejecución remota de código (RCE). Los exploits aparecieron en cuestión de horas y aún hoy siguen detectándose intentos de explotación.

- **SharePoint "ToolShell" (2025)**

  En 2025, varias campañas activas aprovecharon vulnerabilidades en servidores on-premises de Microsoft SharePoint (CVE-2025-49706 y CVE-2025-49704) para lograr acceso inicial y moverse lateralmente en redes corporativas.

Evaluación de las consecuencias de las amenazas y vulnerabilidades.

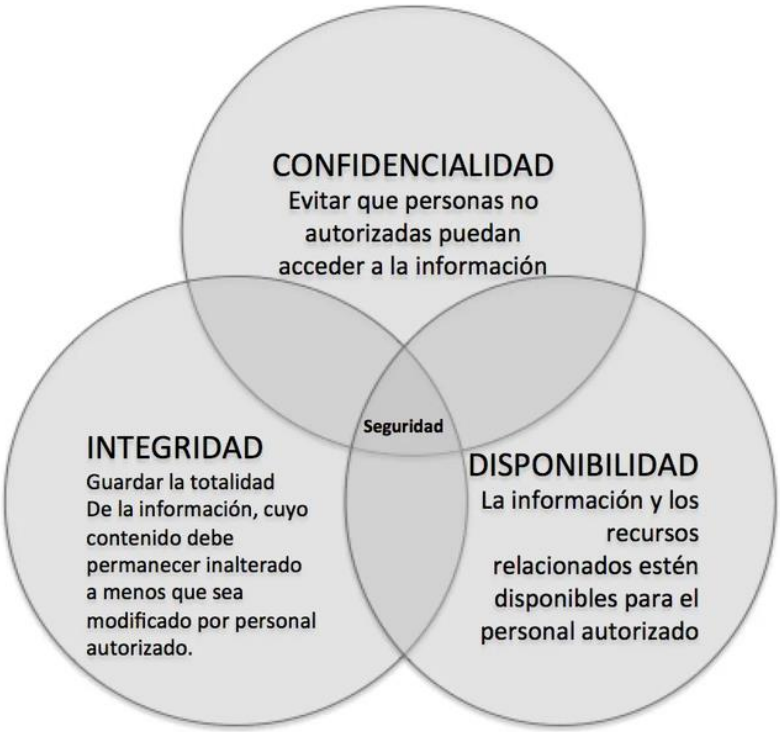
Pasos para Evaluar las Consecuencias

1. **Identificar los activos:** Reconocer qué se quiere proteger (datos, equipos, personas o infraestructura).
2. **Detectar amenazas y debilidades:** Listar los peligros posibles y las fallas de seguridad o de protección existentes.
3. **Calcular la probabilidad:** Estimar qué tan posible es que la amenaza logre explotar la vulnerabilidad.
4. **Medir el impacto:** Analizar la magnitud del daño si el evento sucede (escala de bajo a crítico o de 0 a 1).
5. **Priorizar el riesgo:** Combinar probabilidad e impacto para decidir qué problemas se deben solucionar primero.



Impacto sobre la confidencialidad, la integridad y la disponibilidad.

Determina el daño real que sufre una organización cuando un sistema o dato es atacado, robado o modificado.



Señales y síntomas de amenazas y vulnerabilidades activas.

Los principales signos y síntomas de que tu infraestructura o sistema está bajo un ataque activo o presenta fallos críticos se dividen en las siguientes categorías:

- **Lentitud extrema inexplicable:** Caídas drásticas en la velocidad del sistema, servidores o red sin un aumento real de usuarios legítimos.
- **Consumo de recursos al 100%:** Uso inusualmente alto de la CPU, memoria RAM o disco por procesos desconocidos o procesos legítimos duplicados.
- **Cuelgues y reinicios constantes:** Pantallazos azules, congelamientos o reinicios automáticos de servidores y equipos de trabajo.
- **Antivirus o firewall desactivados:** Programas de seguridad que se apagan solos o alertas de seguridad que desaparecen de los registros.
- **Modificaciones en archivos del sistema:** Archivos críticos modificados, eliminados o con permisos de acceso alterados sospechosamente.

- **Políticas de grupo cambiadas:** Alteraciones en las restricciones de red, firewalls internos o configuraciones de contraseñas sin autorización previa.
- **Bloqueos de cuentas masivos:** Múltiples usuarios bloqueados al mismo tiempo debido a intentos fallidos de inicio de sesión (síntoma de ataque de fuerza bruta).
- **Inicios de sesión anómalos:** Accesos detectados a altas horas de la noche, desde ubicaciones geográficas imposibles o desde dispositivos no registrados.
- **Nuevos usuarios administradores:** Aparición de cuentas con privilegios elevados que ningún departamento de TI ha creado.
- **Picos de tráfico saliente:** Grandes volúmenes de datos que salen de la red hacia servidores externos desconocidos (exfiltración de datos).
- **Conexiones a IPs maliciosas:** Dispositivos internos intentando comunicarse de forma repetida con direcciones IP o dominios catalogados como peligrosos.
- **Consultas DNS masivas:** Comportamiento inusual en las solicitudes de resolución de nombres, que a menudo indica comunicación con redes de bots (*botnets*).
- **Borrado de logs de auditoría:** Registros de eventos que aparecen vacíos o con saltos de tiempo inexplicables (los atacantes suelen borrar sus huellas).

2. Medidas de protección básicas.

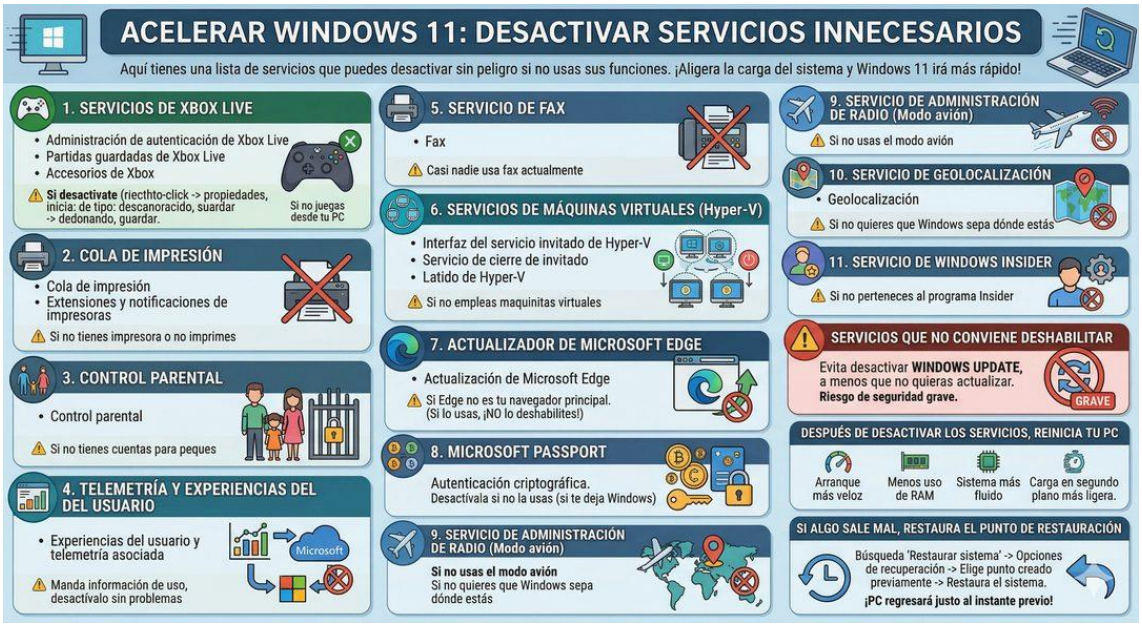
Conceptos básicos

Servicios innecesarios→ Procesos habilitados de fábrica que consumen recursos y abren puertos sin justificación operativa.

Actualizaciones→ Modificaciones de software destinadas a corregir errores funcionales y brechas de seguridad.

Vulnerabilidades conocidas→ Fallos documentados en bases de datos públicas.

Procedimientos para desactivar servicios innecesarios en sistemas operativos



Herramientas para gestionar actualizaciones y parches de seguridad

- NinjaOne Patch Management.
- ManageEngine Patch Manager Plus.
- SolarWinds Patch Manager.
- Ivanti Patch for Endpoint Manager.
- Automox.
- Patch My PC.
- PDQ Deploy.

(Fuente: https://blog.invgate.com/es/software-de-gestion-de-parches)

Gestión de contraseñas robustas

La gestión de contraseñas robustas es el conjunto de prácticas, políticas y tecnologías utilizadas para crear, almacenar, rotar y proteger las credenciales de acceso de los usuarios contra ataques de fuerza bruta, diccionario o ingeniería social.

Características de una contraseña segura

- Longitud adecuada: Mínimo de 12 a 16 caracteres. La longitud es el factor que más dificulta los ataques de fuerza bruta.
- Complejidad y variedad: Uso combinado de letras mayúsculas, minúsculas, números y caracteres especiales ($, @, %, etc.).
- Imprevisibilidad: Evitar palabras de diccionario, fechas de nacimiento, secuencias (123456) o patrones lógicos (qwerty).
- Uso de frases de contraseña (Passphrases): Frases largas compuestas por palabras aleatorias (ej. CaballoAzulVentanaGato!99), que son más fáciles de recordar para el usuario y matemáticamente muy difíciles de descifrar.

Políticas de gestión de contraseñas

- Prohibición de reutilización: Mantener un historial de contraseñas para evitar que el usuario vuelva a utilizar sus últimas 5 a 10 claves.
- Bloqueo de cuenta (Account Lockout): Bloquear temporalmente el acceso tras un número determinado de intentos fallidos (ej. 3 a 5 intentos) para mitigar ataques de fuerza bruta.
- Rotación de contraseñas: Aunque históricamente se exigía el cambio cada 90 días, estándares actuales como NIST recomiendan exigir el cambio solo si hay sospecha de compromiso, ya que la rotación forzada suele llevar a contraseñas más débiles (ej. Password1!, Password2!).
- Uso de gestores de contraseñas: Herramientas centralizadas y cifradas (como Bitwarden, 1Password o KeePass) que generan y almacenan claves únicas para cada servicio.

Métodos de autenticación alternativos: autenticación Multifactor (MFA)

- Aplicaciones autenticadoras: Programas en el móvil (como Microsoft Authenticator o Google Authenticator) que generan códigos temporales o avisos en pantalla.
- Mensajes SMS o llamadas: Códigos de un solo uso enviados al teléfono.
- Llaves de seguridad físicas: Dispositivos USB (como FIDO2) que se conectan al equipo.
- Datos biométricos: Lectura de huella o lectura de cara en el dispositivo.



Recursos multimedia:

- Video explicativo: ¿Qué es la Autenticación Multifactor (MFA)?

Control de accesos y permisos

El control de acceso es el proceso mediante el cual se restringe o se permite el uso de recursos específicos a usuarios o sistemas autenticados, basándose en un conjunto de políticas y reglas predefinidas.

- Principio de Menor Privilegio (PoLP): Otorgar a cada usuario o proceso únicamente los permisos estrictamente necesarios para realizar sus tareas, ni más ni menos.
- Necesidad de saber (Need-to-know): Incluso si un usuario tiene los privilegios técnicos para acceder a un recurso, no debe hacerlo a menos que sea necesario para su función actual.
- Separación de funciones: Dividir tareas críticas entre varios usuarios para que ninguna persona tenga control total sobre un proceso sensible, reduciendo el riesgo de fraude interno.

Gestión de roles y permisos en sistemas operativos

RBAC (Role-Based Access Control): Los permisos se asignan a roles (ej. "Administrador", "Auditor", "Usuario base") y los usuarios se asignan a esos roles, simplificando la gestión a gran escala.

- **Windows:** Utiliza NTFS para asignar permisos de lectura, escritura, modificación y control total a nivel de archivo/carpeta. A nivel de red corporativa, utiliza Active Directory (AD) mediante Grupos de Seguridad.

- **Linux/Unix:** Utiliza un sistema básico de permisos (Lectura r, Escritura w, Ejecución x) divididos en Usuario (Owner), Grupo (Group) y Otros (Others). Se gestionan con comandos como chmod y chown. Para un control más granular se utilizan las ACLs (Listas de Control de Acceso).

Configuración de accesos en redes:

VLANs (Redes de Área Local Virtuales): Segmentación lógica de la red para evitar que un departamento (ej. Invitados) acceda a los recursos de otro (ej. Finanzas).

VPNs y ZTNA (Zero Trust Network Access): Controles para usuarios externos. ZTNA asume que ninguna red es confiable y verifica la identidad y el estado del dispositivo en cada solicitud de acceso.

802.1X y NAC (Network Access Control): Autenticación requerida a nivel de puerto físico o Wi-Fi antes de que el dispositivo obtenga una IP y pueda comunicarse en la red.

Enlaces de interés:

- Documentación de Microsoft sobre Control de Acceso
- Guía de administración de permisos en Linux

Implementación de reglas de firewall

Un firewall (cortafuegos) es un sistema de seguridad de red que monitoriza y controla el tráfico entrante y saliente basándose en reglas de seguridad predeterminadas. Establece una barrera entre redes confiables (internas) y redes no confiables (Internet).

3. Análisis de los incidentes de seguridad.

- **Concepto de incidente de seguridad:** Un incidente es cualquier evento adverso, confirmado o sospechoso, que compromete la seguridad (Confidencialidad, Integridad o Disponibilidad) de los sistemas de información o datos de una organización.
- **Ciclo de vida de un incidente:** Las fases estándar por las que pasa la gestión de un incidente son:
    - **Detección:** Identificación de anomalías, alertas o signos de que algo extraño ocurre en el sistema.
    - **Análisis:** Investigación técnica para determinar el alcance, origen, gravedad y vectores utilizados en el ataque.
    - **Contención:** Aplicación de medidas urgentes para aislar los sistemas afectados y evitar que el daño se propague.
    - **Erradicación:** Eliminación de la causa raíz del problema (por ejemplo, desinfección de malware, cierre de brechas o parcheo).
    - **Recuperación:** Restauración y puesta en marcha de los servicios y sistemas a un estado normal y seguro.
    - **Aprendizaje (Post-mortem):** Análisis posterior para documentar el caso, extraer lecciones y mejorar las defensas futuras.
- **Elementos clave de un incidente:**
    - **Amenazas:** El agente o evento externo/potencial que origina el riesgo.
    - **Vulnerabilidades:** Los fallos o debilidades internas que permitieron que la amenaza triunfara.
    - **Consecuencias:** El impacto real sobre los activos y los objetivos de seguridad (CIA).

- **Tipos de incidentes según su origen:**
    - **Internos:** Provocados por usuarios de la propia organización (empleados, colaboradores), ya sea de forma intencionada o por negligencia.
    - **Externos:** Originados por agentes ajenos a la organización (ciberdelincuentes, atacantes externos).
    - **Dirigidos:** Ataques personalizados y complejos diseñados específicamente contra una empresa o infraestructura concreta (como las APTs o el *spear phishing*).
    - **Masivos:** Ataques automatizados y generalizados que buscan impactar a un gran número de objetivos sin distinción (como campañas de ransomware masivo).
- **Criterios de clasificación:**
    - **Naturaleza:** El tipo de técnica o ataque ejecutado (malware, denegación de servicio, exfiltración de datos).
    - **Alcance:** La magnitud de la infraestructura, número de equipos o volumen de datos afectados.
    - **Objetivo:** Qué pilar de la seguridad se busca comprometer principalmente.

- **Definición de IoC:** Son artefactos, evidencias u observaciones forenses en un sistema o red que indican, con un alto grado de certeza, que se ha producido una intrusión o actividad maliciosa.
- **Tipos de IoC:**
    - **Basados en red:** Direcciones IP maliciosas, dominios de comando y control (C&C), firmas de tráfico anómalas o patrones extraños de transferencia de datos.
    - **Basados en sistema:** Hashes de archivos ejecutables maliciosos, ficheros ocultos en rutas del sistema, modificaciones no autorizadas en el registro del sistema o tareas programadas sospechosas.
    - **Basados en registros (Logs):** Patrones de múltiples intentos fallidos de inicio de sesión, borrado de registros de auditoría o accesos en horarios inusuales.
- **Métodos para identificar IoC:** Uso de herramientas de monitorización y SIEM, análisis de tráfico de red, escáneres de integridad de archivos y herramientas de detección de endpoints (EDR).
- **Relación con técnicas de ataque:** Los IoC son las "huellas dactilares" que dejan las Tácticas, Técnicas y Procedimientos (TTPs) del atacante durante las diferentes fases de su intrusión.

- **Configuración de firewalls e IDS/IPS:** Establecer reglas estrictas de filtrado de tráfico entrante y saliente, monitorizando en tiempo real para bloquear intrusiones antes de que causen daños.
- **Controles de acceso y gestión de contraseñas:** Aplicar el *Principio de Menor Privilegio* (PoLP), exigir contraseñas robustas y utilizar Autenticación Multifactor (MFA).
- **Justificación de las medidas:** Estas acciones reducen drásticamente la superficie de ataque de la organización y mitigan los vectores de entrada más habituales utilizados por los ciberdelincuentes para comprometer los sistemas.

- **Análisis de mitigación de riesgos:** Evaluar cuantitativa y cualitativamente cómo una medida de seguridad reduce la probabilidad de ocurrencia o la gravedad del impacto de una amenaza.
- **Consideraciones de coste-beneficio:** Valorar si el coste económico, de tiempo y de recursos humanos de implementar una solución está justificado frente a las pérdidas potenciales que evitaría un incidente grave.
- **Viabilidad técnica y operativa:** Comprobar que las medidas sean compatibles con la infraestructura tecnológica existente y que los usuarios y administradores puedan operarlas sin obstaculizar la actividad legítima de la empresa.

- **Herramientas y formatos:** Uso de plantillas estandarizadas de respuesta a incidentes, sistemas de ticketing (como Jira o ServiceNow) y formatos de documentación técnica estructurada (Markdown, PDF).
- **Buenas prácticas en la comunicación:**
    - Mantener la objetividad, precisión técnica y claridad.
    - Estructurar el informe lógicamente: Resumen ejecutivo, cronología de eventos, impacto causado, medidas de contención aplicadas y recomendaciones de mejora.
    - Adaptar el nivel técnico del lenguaje según el destinatario (equipos técnicos o directiva de la empresa).

- **Recolección y cadena de custodia:** Captura de evidencias digitales (como volcados de memoria RAM o imágenes forenses de discos) garantizando que los datos no sufran alteraciones y documentando rigurosamente cada persona que los manipula para asegurar su validez judicial.
- **Técnicas fundamentales:** Análisis de líneas temporales (*timelines*), recuperación de archivos borrados, inspección de tráfico de red y análisis forense de memoria.
- **Principios éticos y legales:** Cumplimiento estricto del marco normativo (como el RGPD), respeto a la privacidad y confidencialidad, y actuación siempre bajo la debida autorización legal para evitar la nulidad de las pruebas ante un tribunal.

4.Herramientas y tecnologías de aplicación.

- **Concepto:** Son soluciones de software y hardware diseñadas específicamente para proteger los sistemas de información, redes, dispositivos y datos frente a accesos no autorizados, malware y ciberataques.
- **Tipos principales:**
    - **Cortafuegos (Firewalls):** Controlan y filtran el tráfico de red en función de políticas de seguridad predefinidas.
    - **Control de accesos:** Administran los permisos de diferentes usuarios que utilizan el equipo o la red. Como factores de autenticación multifactorial (MFA).
    - **Sistemas IDS/IPS:** Monitorizan la red o los sistemas en busca de actividades sospechosas o intentos de intrusión.
    - **Software Antivirus y Antimalware:** Detectan, bloquean y eliminan códigos maliciosos en los equipos terminales (*endpoints*).
- **Importancia de la configuración adecuada:** Una mala configuración de estas herramientas puede dejar puertos críticos abiertos, generar falsos positivos masivos que saturen a los administradores o crear una falsa sensación de seguridad, dejando la infraestructura vulnerable.

- **Tipos de cortafuegos:**
    - **Basados en red:** Dispositivos de hardware o programas dedicados a inspeccionar y filtrar todo el trafico de red que entra y sale de una red concreta. Se sitúa como frontera entre la red privada y la red publica (puede ser internet, u otra red grande que sirva como segmento de otra unidad corporativa).
    - **Basados en host:** Software instalado directamente en un sistema operativo específico (ejem: *Windows Defender Firewall*) para proteger un equipo individual. Controla y filtra todo el trafico que entra y sale también, pero únicamente de este equipo en particular.
- **Instalación y configuración:**
    - **Configuración básica:** Establecer políticas estrictas por defecto (bloquear todo el tráfico entrante y permitir únicamente los servicios esenciales autorizados).
    - **Configuración avanzada:** Creación de reglas personalizadas basadas en direcciones IP de origen/destino, puertos específicos, protocolos, filtrado de estados (*stateful inspection*) y control de tráfico saliente (*egress filtering*).
    - **Pruebas funcionales:** Uso de herramientas de escaneo de puertos (como *Nmap*) o pruebas de conectividad para verificar que las reglas aplicadas bloquean o permiten el tráfico según lo previsto.

- **Concepto:** Son sistemas diseñados para proteger redes y equipos contra accesos no autorizados y actividades maliciosas.
- **Diferencias entre IDS y IPS:**
    - **IDS (Intrusion Detection System):** Es un sistema pasivo. Analiza el tráfico y los registros, detecta patrones maliciosos y genera alertas para que los administradores tomen medidas, pero no interrumpe el tráfico por sí mismo.
    - **IPS (Intrusion Prevention System):** Es un sistema activo situado en línea con el flujo de red. Además de detectar la amenaza, toma acciones como descartar paquetes maliciosos, bloquear direcciones IP, cerrar puertos o desconectar sesiones.
- **Instalación y configuración:**
    - **Parámetros básicos:** Definición de interfaces de red de escucha, selección de conjuntos de reglas (*rule sets*) y actualización de firmas de ataques.
    - **Ajustes avanzados:** Personalización de umbrales de alerta, creación de reglas heurísticas propias y supresión de falsos positivos recurrentes.
    - **Verificación del funcionamiento:** Ejecución de pruebas controladas (como patrones de prueba de intrusión) para comprobar que el sistema genera las alertas correctas o bloquea el tráfico anómalo.

Software antivirus y malware.

- **Funciones y tipos:** Protegen los equipos identificando firmas de virus conocidas, analizando comportamientos mediante heurística y supervisando la ejecución de procesos y ficheros en memoria. Se clasifican en soluciones locales para usuarios, consolas de gestión centralizada para empresas y herramientas en la nube.
- **Instalación y configuración inicial:** Despliegue del agente de seguridad, programación de análisis periódicos (completos y rápidos) y activación de la protección residente en tiempo real.
- **Actualización y validación:** Actualización continua de las bases de datos de firmas y motores de análisis. Validación del correcto funcionamiento mediante pruebas de detección controladas utilizando archivos estándar seguros (como el fichero de pruebas *EICAR*) para verificar que el antivirus aísla la amenaza y genera el informe correspondiente sin comprometer el equipo.

- **Integración:** Asegurar que las herramientas de ciberseguridad convivan de manera fluida con los servicios del sistema operativo, las aplicaciones corporativas y la arquitectura de red existente.
- **Maximización del rendimiento:** Ajustar las frecuencias y prioridades de los análisis para evitar cuellos de botella en la CPU o el almacenamiento, y excluir directorios de alta actividad temporal cuando sea estrictamente seguro.
- **Resolución de conflictos:** Identificar y corregir bloqueos derivados de reglas de seguridad demasiado agresivas que interfieren con herramientas de administración legítimas o la conectividad interna de la empresa.

- **Simulación de escenarios de ataque:** Uso de herramientas de pruebas controladas (como *Metasploit* o scripts de emulación de amenazas) para replicar comportamientos maliciosos reales.
- **Evaluación de la respuesta:** Medir métricas clave como el tiempo de reacción, la precisión en la identificación del vector de ataque y la eficacia en el bloqueo automático por parte de las defensas.
- **Identificación y resolución de errores:** Detectar reglas ineficientes, solapamiento de políticas o exclusiones peligrosas para refinar y fortalecer la postura de seguridad de la infraestructura.

- **Elementos de la documentación técnica:** Registro detallado de la arquitectura de seguridad implementada, inventario de reglas de cortafuegos, políticas de IDS/IPS, versiones de software y datos de contacto de los administradores responsables.
- **Uso de plantillas:** Utilización de formatos estandarizados para documentar de forma estructurada los procedimientos de instalación, los cambios de configuración y las incidencias resueltas.
- **Mantenimiento y actualización:** Establecer un calendario periódico para revisar las políticas de seguridad, realizar auditorías de configuración y aplicar actualizaciones de parches en las propias herramientas de protección.

5.Normativa y buenas prácticas de uso.

a) Concepto y objetivos de la seguridad de la información. Principios fundamentales e importancia del cumplimiento.

- **Concepto y objetivos:** Conjunto de medidas, políticas y tecnologías destinadas a proteger los activos de información de una organización frente a cualquier amenaza, garantizando la continuidad del negocio.
- **Principios fundamentales (Tríada CIA):**
  - **Confidencialidad:** Garantiza que la información solo sea accesible por personal debidamente autorizado.
  - **Integridad:** Asegura que los datos sean exactos, fiables y estén protegidos contra modificaciones no autorizadas o accidentales.
  - **Disponibilidad:** Asegura el acceso oportuno y continuo a los datos y recursos por parte de los usuarios autorizados.
- **Importancia del cumplimiento:** El acatamiento de las normativas y buenas prácticas en entornos profesionales evita sanciones legales graves, protege la reputación corporativa y asegura la confianza de clientes y socios comerciales.

b) Normativas y estándares internacionales en ciberseguridad.

- **Reglamento General de Protección de Datos (RGPD):** Normativa europea de obligado cumplimiento que regula la privacidad y el tratamiento de los datos personales de los ciudadanos, estableciendo fuertes sanciones por brechas de seguridad o negligencias.
- **ISO/IEC 27001:** Estándar internacional de referencia para los Sistemas de Gestión de la Seguridad de la Información (SGSI), que proporciona un marco estructurado para evaluar, implementar y certificar la seguridad en una organización.
- **Esquema Nacional de Seguridad (ENS):** Marco legal en España que establece los principios básicos y requisitos mínimos de seguridad para la protección de la información en el ámbito del sector público y entidades colaboradoras.

c) Buenas prácticas en la gestión de la seguridad de la información.

- **Clasificación de datos sensibles:** Categorizar la información según su nivel de criticidad o confidencialidad (pública, interna, confidencial o restringida) para aplicar los controles de protección adecuados.

- **Definición de políticas de acceso:** Establecer reglas claras basadas en el *Principio de Menor Privilegio* (PoLP) y la necesidad de saber para limitar el acceso exclusivamente a los recursos indispensables para cada función.
- **Gestión del ciclo de vida de la información:** Controlar de forma segura todas las fases por las que pasa un dato, desde su creación y almacenamiento hasta su uso, compartición, archivado y borrado o destrucción definitiva.

d) Evaluación de medidas de seguridad en escenarios prácticos.

- **Análisis de casos:** Estudio de situaciones reales de brechas o fallos de seguridad para comprender cómo se originaron y qué defensas fallaron.
- **Herramientas de auditoría:** Uso de software especializado para escanear vulnerabilidades, revisar configuraciones y comprobar el estado real de la seguridad técnica.
- **Diagnóstico de fallos y propuestas de mejora:** Identificación de brechas operativas o técnicas y diseño de soluciones correctoras para blindar los sistemas frente a incidentes futuros.

e) Gestión de riesgos y mejora continua.

- **Identificación y evaluación de riesgos:** Detección sistemática de los activos críticos, las amenazas potenciales y las vulnerabilidades existentes para calcular su nivel de impacto y probabilidad.
- **Desarrollo de planes de acción:** Creación de estrategias orientadas a mitigar, transferir, aceptar o evitar los riesgos detectados.
- **Revisión y actualización:** Necesidad de auditar y actualizar periódicamente las políticas de seguridad para adaptarlas a un entorno tecnológico y de ciberamenazas en constante evolución.

f) Documentación de la gestión de la seguridad de la información.

- **Elaboración de procedimientos y políticas:** Redacción formal de normativas internas, guías de actuación y manuales técnicos que estipulen cómo debe actuar el personal.
- **Registro de incidencias y cumplimiento:** Mantener bitácoras detalladas de los eventos adversos ocurridos, las medidas aplicadas y las auditorías de cumplimiento normativo.
- **Plantillas y formatos estándares:** Uso de estructuras normalizadas para facilitar la lectura, el archivo y la trazabilidad de la documentación técnica.

Webgrafía

Conceptos Básicos de Ciberseguridad

- Confidencialidad (Wikipedia)
- Integridad Informática (Protección Datos LOPD)
- Disponibilidad en Seguridad Informática (UNIR)
- La disponibilidad como eje de la ciberseguridad industrial (Becolve)

Amenazas, Malware y Tipos de Ataques

- Qué es el Sniffing y cómo evitarlo (Red Seguridad)
- Análisis de tráfico (Wikipedia)
- Definición de Spoofing (Kaspersky)
- Ataques de Denegación de Servicio - DoS (Cloudflare)
- Qué es el Ransomware (IBM)
- Tipos de Malware (Kaspersky)
- Ingeniería Social (Consejo Europeo)
- Ataques a Aplicaciones Web (Akamai)
- Qué es un Exploit en ciberseguridad (Inforges)
- Publicación sobre ciberseguridad en redes sociales (X)

Vulnerabilidades y Análisis de Riesgos

- Tipos de vulnerabilidad informática (LinkedIn)
- Diferencias entre amenazas y vulnerabilidades (OpenWebinars)
- Vulnerabilidades, amenazas y ataques (CAIB)
- Evaluación de Vulnerabilidades (SentinelOne)
- Análisis de Riesgo en 5 pasos (LinkedIn)
- Diferencias entre amenazas, vulnerabilidades y riesgos (Sectigo)

Medidas de Protección, Configuración y Buenas Prácticas

- Cifrado Wi-Fi y Windows 11 (Banda Ancha)
- Configuración segura de activos y software (ISC)
- Infografía: Crea tu contraseña segura (INCIBE)

Recursos Multimedia (YouTube)

- Vídeo: Claves para proteger tu software / OWASP
- Vídeo: Hacking Paso a Paso desde Cero